

Sheeraz Ali

Security Engineering Leader · AI & Offensive Security Researcher · CTO at Pwned Labs

Bhopal, India (Remote) · hi@sheerazali.com · +91 79742 34098 · sheerazali.com · linkedin.com/in/beingsheerazali · github.com/pwnmeow

SUMMARY

Offensive security leader with 7+ years across penetration testing, vulnerability research, and security engineering — specialized in **AI/LLM penetration testing**, equally deep across web, API, mobile, cloud, and internal network testing. Delivered **245 penetration tests** and reported **1,592 vulnerabilities** for Cobalt customers; credited with **28+ CVEs** from original zero-day research; built **300+ hacking machines, challenges, and labs** for Hack The Box's 2M+ user platform. Now CTO of Pwned Labs — architect and builder of the entire hands-on cloud, AI, and Kubernetes training platform used by **40,000+ practitioners**. OSCP and CREST certified; **Black Hat Arsenal** tool author; conference speaker (Nullcon, c0c0n); BSides Bangalore “**Cybersecurity Samurai of the Year 2023**.”

CORE SKILLS

AI Security	AI/LLM & agent pentesting, prompt injection & jailbreaks, RAG and tool-abuse attack chains, OWASP LLM Top 10, guardrail bypass, model/API abuse
Offensive Security	Web / API / network / mobile / cloud penetration testing, red teaming, Active Directory attacks, vulnerability research, exploit development
Cloud & Platform	AWS, Azure, Kubernetes, Docker, CI/CD security, Linux administration
Security Engineering	Secure code review, SAST at scale (Semgrep), threat modeling, secure SDLC, vulnerability management
Engineering	Python, JavaScript/Node.js, Bash, SQL, MongoDB, automation & tooling, infrastructure as code
Standards & Tooling	OWASP Top 10 / ASVS, MITRE ATT&CK, PTES, Burp Suite Pro, Metasploit, Nmap, BloodHound

EXPERIENCE

Chief Technology Officer — Pwned Labs

Aug 2025 – Present

Remote · Hands-on cloud, AI & Kubernetes security training platform

- Designed, built, and shipped the **entire platform end-to-end** — product, backend, lab-provisioning and orchestration engine, and certification-exam infrastructure — serving **40,000+ users** and a 10,000+ member community.
- Own security engineering across the stack: application security, multi-cloud infrastructure hardening (AWS/Azure/GCP), identity and access management, and secure SDLC — for a platform whose user base is professional hackers.
- Architect real-infrastructure cyber ranges and enterprise training across cloud, AI/LLM, Kubernetes, and CI/CD security — real cloud environments, not simulations — including **PwnCloud OS**, a purpose-built operating system for cloud penetration testing.
- Lead a cross-functional team of 6 developers and 2 security engineers**; own cloud budgeting and cost optimization across on-demand multi-cloud lab fleets.

Lead Pentester (Part-time) — Cobalt

Oct 2021 – Present

Remote · Promoted from Penetration Tester, Dec 2022

- Delivered **245 penetration test engagements** end-to-end and reported **1,592 vulnerabilities** across AI/LLM systems, cloud environments (AWS/Azure/GCP), web applications, APIs, networks, mobile apps, and Chrome extensions.
- Lead collaborative pentests as engagement lead: scoping, methodology, triage, client communication, and report quality for Fortune-500 and high-growth SaaS customers.
- Ran **AI/LLM penetration tests** against production chatbots, copilots, and agentic systems — prompt injection, jailbreaks, sensitive-data exfiltration, and tool-abuse attack chains.
- Co-created and hosted “**Hacker's Corner**,” Cobalt's security podcast on red teaming and pentest tradecraft.

Senior Security Engineer — SolarWinds

Sep 2024 – Aug 2025

Remote (US team)

- Delivered **120+ internal penetration tests** across the observability and IT-management portfolio (web, API, cloud, thick-client) under SolarWinds' Secure-by-Design program.
- Built the penetration-testing program from the ground up**: scoping, methodology, reporting standards, and the remediation workflow adopted across product teams.
- Set up and led the offensive security team** — hired, managed, and mentored 3 junior security engineers, reviewing their engagements for quality.
- Ran secure design reviews and threat modeling with engineering teams; built triage automation that **cut mean vulnerability resolution time from ~3 months to 40 days**.

Remote (UK) · World's largest hands-on hacking platform

- Engineered, exploited, and shipped **300+ machines, CTF challenges, and labs** for the world's largest hacking platform (**2M+ registered users**) — spanning Active Directory, Kubernetes, AWS cloud attacks, web exploitation, reverse engineering, and Linux/Windows privilege escalation.
- Authored flagship machines — *PikaTwoo* (Insane-rated, 5/5 community rating), *Pikaboo* (Hard), and *Love* — each played by hundreds of thousands of users.
- Ran pre-release penetration testing and QA on all production content; built automated Python/Bash test harnesses that accelerated release cycles and eliminated regression bugs in shipped labs.
- Co-authored rapid-response public research on **Dirty Pipe (CVE-2022-0847)** and **Spring4Shell (CVE-2022-22965)** within days of disclosure.
- Cut lab infrastructure cost through VM/container image optimization; delivered Kubernetes exploitation training at Cyber Apocalypse CTF (**10,000+ players**).

Security Researcher — Code Vigilant (open source)

Jan 2021 – Present

Volunteer coordinated-disclosure collective

- Credited with **28+ CVEs**, including 21 zero-days in WordPress plugins (SQL injection, XSS, CSRF) found via source-code review at scale.
- Built a Semgrep static-analysis pipeline that scanned the entire 80,000-plugin WordPress repository, surfacing **4,200+ candidate SQLi/XSS/SSRF issues**; presented at **Nullcon Goa 2022** and **c0c0n XV**.

Information Security Analyst (Internship) — Enciphers

Dec 2019 – Jul 2020

- Co-developed **Mobexler**, the mobile-app pentesting VM later showcased at **Black Hat Arsenal**; conducted web application pentests and built internal vulnerable training labs.

COMMUNITY LEADERSHIP

- Chapter Lead, null — The Open Security Community, Bhopal** (Oct 2019 – Sep 2023): ran one of India's largest open security community chapters — monthly talks, hands-on workshops, vulnerable-lab build-outs, speaker management.
- Speaker/Lead**, Google Developer Groups & Facebook Developer Circles Bhopal (2019–2020); **City Coordinator**, Hour of Code (Code.org); **Team Lead**, OWASP Seaside.
- Founder, Hacking Laymen** (2018–2020) — free security & coding education initiative featured in local press.

TALKS, RESEARCH & MEDIA

- Black Hat Arsenal** — Mobexler pentesting VM (co-developer); **Nullcon Goa 2022** — “Raining CVEs on WordPress Plugins with Semgrep” (speaker)
- c0c0n XV, 2022** — automated code review at scale (speaker); **Seasides 2022** — drone hacking workshop (trainer)
- HTB Cyber Apocalypse 2022** — Kubernetes exploitation talk; **BSides Ahmedabad 2019** — lock-picking village, featured in *Times of India*
- Host, “Hacker's Corner” podcast** (Cobalt); technical blog at sheerazali.com; Cybrary article with 18,000+ reads

CERTIFICATIONS

OSCP — Offensive Security Certified Professional (2020)
CREST CRT — Registered Penetration Tester (2022)
CREST CPSA — Practitioner Security Analyst (2022)
CRTP — Certified Red Team Professional (2021)
CRTE — Certified Red Team Expert (2021)
HTB CBBH — Certified Bug Bounty Hunter (2022)
CKA — Certified Kubernetes Administrator (2021)
HTB Pro Labs: **Dante · Offshore · Hailstorm (AWS)**

HONORS & CTF

Cybersecurity Samurai of the Year 2023 — BSides Bangalore
1st — Nullcon Cisco/Checkpoint CTF (2019) · 1st — Sector443 CTF (2019)
3rd — c0c0n XI Red Team Village CTF (2018) · 6th — OWASP Seaside Intl. CTF (530 players)
Hack The Box **Elite Hacker** (109+ machines owned)

EDUCATION

Bachelor of Computer Applications (Computer Science)
The Bhopal School of Social Sciences · 2017–2020